

Defend Without Destroying: Typed Safety Constraints for Reinforcement-Learning Cyber Defence Agents in Simulation

Anonymous Author(s)
(double-blind submission)

Abstract

A reinforcement-learning (RL) cyber-defence agent cannot simply maximise cumulative reward when its actions can disconnect production machines, block legitimate traffic, or destroy forensic evidence. Existing autonomous cyber defence (ACD) work either folds such harms into a hand-tuned reward or, more recently, treats them uniformly as Lagrangian budgets that are satisfied only in expectation. We argue that *constraints have types*: downtime and blocked traffic are *budget* constraints, whereas evidence destruction and severing a safety-critical asset are *hard*, irreversible constraints, and the safety mechanism should follow the type. We present SAFEACD-SIM, an open-source discrete-time simulation model of a CAGE-2-like enterprise/OT network that emits security reward and four defender-induced harm channels separately, and a TYPED agent that combines PPO-Lagrangian for budgets with a runtime shield, built only from SOC-observable signals, for hard rules (“image before reimage”, “never isolate the OT controller”). Using a pre-registered protocol with common random numbers, ten seeds, and a held-out attacker, we compare reward-only PPO, reward shaping, PPO-Lagrangian, shielded PPO and TYPED. Reward-only PPO attains the best security score by severing the OT controller and blocking legitimate traffic at many times the budget. Shaping and PPO-Lagrangian keep downtime within budget but still violate a hard constraint in 94.3% and 50.8% of episodes respectively, the latter despite an evidence multiplier near 23.4. TYPED meets both budgets and is free of hard violations in 97.7% of episodes; the residual is attributable to undetected compromises. Simulator, agents and protocol are released for reproduction.

Keywords: autonomous cyber defence, safe reinforcement learning, constrained MDP, shielding, digital forensics, simulation.

1 Introduction

Autonomous cyber defence (ACD) agents trained with deep reinforcement learning in simulated “cyber gyms” such as CyBORG [20, 28] can now contain scripted intruders at machine speed [9, 25, 35]. Their training objective, however, is almost always a single scalar reward. Whenever a defensive action is effective *because* it is harmful—quarantining a subnet, severing an industrial controller, or reimaging a host before anyone has imaged it—a reward-maximising agent will learn to use it. The resulting policies look excellent on the security metric and are unacceptable to the security operations centre (SOC) that would have to deploy them.

The community’s first response was reward engineering: penalties for restores or for disrupting simulated users [20]. Recent analyses show that dense, engineered rewards bias agents towards riskier policies [5, 6]. The second response, emerging in 2026, moves operational costs into a constrained MDP (CMDP) [4] and enforces budgets with Lagrangian multipliers [33]. Lagrangian methods, however, guarantee constraint satisfaction only *in expectation and asymptotically* [26, 29]: an acceptable contract for “at most ten server-hours of downtime per incident”, but not for “never destroy the evidence of an intrusion”, which incident-response standards treat as non-negotiable [7, 19, 23].

This paper makes the observation that the harms an ACD agent can cause have different *types*, and that the safety mechanism should be chosen per type. Our contributions are:

1. **A typed safety formulation for ACD.** We separate *budget* constraints (production downtime, blocked legitimate traffic) from *hard* constraints (forensic-evidence destruction, isolation of a safety-critical OT asset), and pair the former with Lagrangian relaxation and the latter with a preemptive shield [3] whose rules use only SOC-observable information. To our knowledge this is the first RL-ACD work to model evidence preservation as an explicit, irreversible constraint.

2. **SAFEACD-SIM, an open simulation model** of a 12-host user/enterprise/operational network (mirroring CAGE-2) with scripted attackers, benign traffic, forensic imaging, and *separate* reward and harm channels, together with its verification and validation (V&V) evidence.
3. **A pre-registered simulation experiment** (5 learning conditions, 3 reference policies, 10 seeds, 3 attackers, common random numbers) that quantifies (RQ1) the harm of reward maximisation and the fragility of reward shaping, (RQ2) typed versus untyped constraint handling, (RQ3) whether the shield must be present during training, and (RQ4) robustness to a held-out attacker, reporting monitor-relative residual violations honestly.

2 Background and Related Work

RL for autonomous cyber defence. CybORG and its CAGE challenges [20, 28] are the de-facto benchmarks; hierarchical and multi-agent PPO agents dominate them [9]. Surveys [21, 25, 35] identify the gap between simulated performance and deployability, and a 2026 expert workshop distilled environment-design guidelines [34]. Environment extensions add realistic actions such as isolation [32], and cyber-range studies evaluate availability costs of learned responders [24]. Optimal stopping formulations offer an analytic alternative [13].

Rewards, constraints and safety in ACD. Dutta et al. [8] verified RL decisions against SMT-encoded requirements. Bates et al. [5, 6] showed that sparse, goal-aligned rewards yield lower-risk policies than dense penalties. Closest to us, ACD³-GAT [33] formulates multi-agent ACD as a CMDP with budgets on mean time to recover, false-positive responses and firewall change disruption, enforced by Lagrangian control and counterfactual screening; all of its constraints are budgets. Hsain and Almuhammadi [15] use shield synthesis for *design-time* defensibility analysis rather than runtime enforcement, and Jamshidi et al. [17] combine PPO with action masking under control-plane safety constraints in SDN-IoT. None of these models forensic evidence, and none assigns mechanisms by constraint type.

Safe RL. A CMDP [4] adds cost signals c_k and thresholds d_k to an MDP and seeks $\max_{\pi} J_r(\pi)$ s.t. $J_{c_k}(\pi) \leq d_k$. Trust-region [1] and Lagrangian [26, 31] methods solve it in expectation; Lagrangian multipliers are known to overshoot and oscillate [29]. Shielding [3] instead removes unsafe actions before (preemptive) or after (post-posed) the agent chooses, giving per-step guarantees relative to the shield’s model; invalid-action masking keeps policy gradients well defined [16]. Irreversible actions are a recognised hazard [11]. See [10, 12] for surveys.

Forensic readiness. NIST SP 800-86 and SP 800-61r3 require evidence to be preserved during containment and eradication [19, 23]; RFC 3227 orders artefacts by volatility [7]. The operational rule of thumb is “image before you reimaging”: reimaging restores service but irreversibly erases the artefacts needed for attribution, scoping and legal action.

3 Typed Safety Constraints

We model the defender’s problem as a partially observable CMDP with security reward r and four harm costs $c_1 \dots c_4$, each counting only *defender-induced* harm:

- c_{prod} – criticality-weighted host-steps offline (isolated or being reimaged);
- c_{traf} – weight of active legitimate flows that could not be served;
- c_{evid} – reimages of a compromised host whose current incident was never imaged;
- c_{crit} – steps in which the safety-critical OT controller is isolated.

We partition constraints into a *budget* set $\mathcal{B} = \{\text{prod}, \text{traf}\}$, $\mathbb{E}_{\pi}[\sum_t c_k] \leq d_k$, and a *hard* set $\mathcal{H} = \{\text{evid}, \text{crit}\}$ that must hold on every trajectory, $\Pr_{\pi}[\sum_t c_k > 0] = 0$.

Mechanism per type. TYPED solves the budget part by Lagrangian relaxation,

$$\max_{\pi} \min_{\lambda \geq 0} J_r(\pi) - \sum_{k \in \mathcal{B}} \lambda_k (J_{c_k}(\pi) - d_k), \quad (1)$$

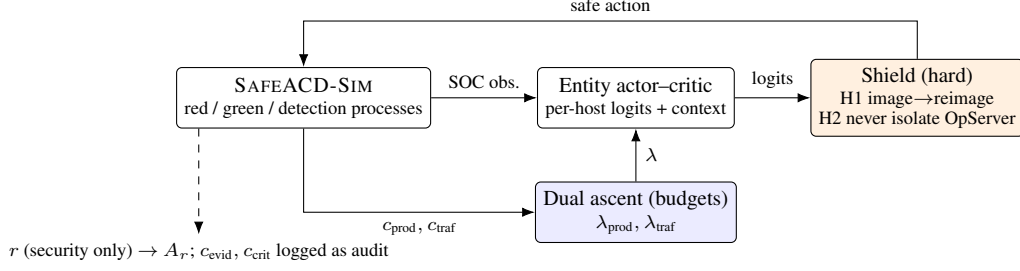


Figure 1: TYPED agent in the loop. Budget harms are priced by Lagrange multipliers; hard harms are prevented by a preemptive shield that reads only SOC-observable state. All four harm channels are logged for every method.

using PPO [27] on the normalised combined advantage $(A_r - \sum_k \lambda_k A_{c_k}) / (1 + \sum_k \lambda_k)$ as in OmniSafe [18] and projected dual ascent on λ (Section 5), and enforces the hard part with a preemptive shield that masks unsafe actions before sampling:

- H1** *Image before reimage*: $\text{Restore}(h)$ is allowed only if a forensic image of h exists that post-dates the host’s open SOC ticket and its last reimage.
- H2** *Never sever the OT controller*: $\text{Isolate}(\text{OpServer})$ is never allowed.

Monitor-relative guarantees. The shield reads only what a SOC has—tickets and image timestamps—never the simulator’s ground truth. H2 is therefore enforced exactly, whereas H1 holds *relative to the monitor*: a compromise that begins after an image and is never detected can still lose artefacts on reimage. We measure this residual rather than claim zero violations by construction.

4 The SAFEACD-SIM Simulation Model

Structure. SAFEACD-SIM is a discrete-time stochastic simulation (100 steps per episode) of 12 hosts in three subnets mirroring CAGE-2: five user workstations, three enterprise servers (Ent0–Ent2) and an operational subnet with the safety-critical OpServer and three OT hosts. Two zone links (user→enterprise, enterprise→operational) can be blocked. Each step the blue agent acts, the red agent acts, benign traffic is sampled, alerts are generated, and reward and costs are emitted (Table 1).

Red agents. Red progresses along an attack graph: an exploit within a zone needs a user-level foothold, crossing a zone needs a privileged one; escalation turns user into privileged access; a privileged foothold on the OpServer allows a mission *impact*. **B-line** heads straight for the OpServer; **Meander** escalates everywhere and expands subnet by subnet; the held-out **Stealthy** attacker is B-line with 30% dwell and 60% lower detection probability. The initial foothold is a random, undetected user host, and an attacker left without a usable foothold re-phishes with probability 0.1.

Benign traffic and evidence. Fifteen weighted business flows (web, file, authentication, historian, control loop) are active with fixed probabilities; a flow is served only if both endpoints are online and the zone link is open. Evidence is *incident-scoped*: the first compromise of a clean host opens an incident; a forensic image taken afterwards preserves it until the host is reimaged.

Defender interface. 77 discrete actions: **Sleep**; per-host **Analyse**, **Forensics** (image), **Remove** (evicts user-level access only), **Restore** (reimage, host offline for two steps), **Isolate**, **Reconnect**; and **Block/Unblock** per zone link. The 87-dimensional observation contains, per host, the SOC ticket severity, the alert raised this step, isolation and reimaging flags, and whether a valid image exists, plus link states and time.

Table 1: Main SAFEACD-SIM parameters (defaults in `safeacd/env.py`).

Parameter	Value
Horizon / restore downtime	100 steps / 2 steps
$P(\text{exploit}), P(\text{escalate})$	0.75, 0.80
$P(\text{detect exploit} / \text{escalate} / \text{impact})$	0.85 / 0.70 / 1.0 (Stealthy: $\times 0.4$)
$P(\text{false alert per host-step}), P(\text{re-phish})$	0.01, 0.1
Security reward	$-\sum_h v_h (0.5 [\text{user}] + 1 [\text{priv}]) - 10 [\text{impact}]; v = 0.1 \text{ users/OT hosts, 1 servers}$
Downtime weights	users 0.1, servers/OT hosts 1, OpServer 2
Budgets d (prod, traf, evid, crit)	10, 50, 0, 0 per episode

Table 2: Operational validation with reference policies (100 CRN episodes per attacker; per-episode means). R: security return; prod/traf: downtime and blocked-traffic cost. No reference policy destroyed evidence; the reward hacker isolates the OpServer in every step (100 critical violations).

Policy	B-line			Meander		
	R	prod	traf	R	prod	traf
No defence	-1172.7	0.0	0.0	-1131.0	0.0	0.0
Random	-528.8	328.8	1019.4	-387.1	328.8	1019.4
SOC playbook (image before reimage)	-78.8	12.5	52.4	-13.3	3.2	31.0
“Isolate OpServer + block”	-47.6	200.0	1319.2	-47.6	200.0	1319.2

Verification and validation. Twenty-four automated tests verify determinism under seeding, the cost semantics (image-then-reimage costs no evidence; reimage-without-image costs one; the critical rule; blocked-link traffic loss) and the shield invariants. For operational validation we ran four reference policies on the evaluation seeds (Table 2). The ordering matches expert expectation, and the last row exposes the paper’s motivating problem: the policy with the best *security* return against B-line is the most harmful one. Pilot runs also revealed two modelling artefacts that we fixed before the main experiment and report as V&V lessons: (i) a fixed initial foothold (the CAGE-2 convention) let every learner quarantine one workstation forever and freeze the attacker; (ii) alert-scoped evidence created a dead-lock in which an attacker acting on a host invalidated every new image.

5 Experimental Design

Conditions. All learning conditions share one PPO implementation and hyper-parameters (8 environments $\times$ 256 steps, 10 epochs, minibatch 256, learning rate $3 \cdot 10^{-4}$, $\gamma = 0.99$, GAE $\lambda = 0.95$, clip 0.2, entropy 0.01) and one *entity-based* actor–critic [30]: a 64-unit encoder shared by all hosts, a permutation-invariant pooled context, a per-host head producing that host’s six action logits, a global head for Sleep/Block/Unblock, and a critic with one reward and four cost heads. Lagrange multipliers follow clipped, budget-normalised projected ascent, $\lambda_k \leftarrow \max(0, \lambda_k + 0.05 \text{ clip}((J_k - d_k) / \max(d_k, 1), -1, 1))$, which bounds overshoot in both directions [29]. Conditions differ only in safety handling: **PPO** (security reward only); **Shaped- β** (reward minus $\beta(c_{\text{prod}} + c_{\text{traf}} + 10c_{\text{evid}} + 10c_{\text{crit}})$, $\beta = 1$ in the main grid, $\beta \in \{0.1, 0.3, 3, 10\}$ in a sweep); **Lag** (PPO-Lagrangian on all four channels with $d = (10, 50, 0, 0)$); **Shield** (security reward plus shield); and **TYPED** (Lagrangian on the two budgets plus shield). Invalid-action masking is applied everywhere. The budgets encode “no more collateral harm than the incumbent playbook”: the playbook’s mean downtime and traffic cost under the training distribution are 7.9 and 41.7.

Protocol. Each condition is trained for 10^6 steps on a uniform B-line/Meander mixture with ten independent seeds (seeds 1–10; seed 0 was reserved for pilot runs that fixed the architecture and dual step) and three seeds per β in the sweep. Each trained stochastic policy is evaluated for 100 episodes per attacker, including the held-out Stealthy attacker. Evaluation episode i uses the same seed for every policy, and the red, green and detection processes draw from independent random streams, so comparisons use *common random numbers* [22]. For RQ3 we additionally deploy the unshielded policies with the shield attached (“+S”). We report seed-level means with 95% percentile-bootstrap CIs and IQM [2, 14]; pre-registered comparisons use Mann–Whitney U tests on seed means and, against the

Table 3: Deployment performance under the training attacker distribution (B-line/Meander mixture). Mean over seeds with 95% bootstrap CI over seeds; 100 common-random-number episodes per attacker. Bottom block (RQ3): unshielded policies deployed with the shield attached.

Method	Security return $\uparrow$	Downtime $\downarrow$ (budget 10)	Blocked traffic $\downarrow$ (budget 50)	Evidence destroyed $\downarrow$ (budget 0)	Critical viol. $\downarrow$ (budget 0)	$P(\text{no hard viol.}) \uparrow$	$P(\text{all satisfied}) \uparrow$
SOC playbook	-46.0	7.9	41.7	0.00	0.00	1.000	0.65
PPO (reward only)	-1.5 [-2.0, -1.1]	494.1 [289.0, 668.1]	1181.0 [950.4, 1395.2]	4.30 [2.49, 6.77]	59.82 [33.82, 83.46]	0.002 [0.000, 0.006]	0.00
Shaped ($\beta=1$)	-36.1 [-40.0, -32.5]	4.2 [3.6, 4.9]	21.5 [18.6, 24.6]	3.02 [2.69, 3.34]	0.00 [0.00, 0.01]	0.057 [0.039, 0.079]	0.06 [0.04, 0.08]
PPO-Lagrangian	-60.5 [-65.5, -56.7]	8.1 [7.0, 9.1]	54.4 [45.8, 65.7]	1.01 [0.48, 1.59]	0.11 [0.05, 0.19]	0.492 [0.304, 0.680]	0.34 [0.22, 0.46]
PPO+Shield	-1.6 [-1.8, -1.4]	196.8 [60.5, 341.3]	845.6 [661.2, 1056.0]	0.01 [0.00, 0.02]	0.00	0.990 [0.982, 0.998]	0.00
Typed (Lag+Shield)	-61.0 [-67.7, -55.1]	8.0 [7.0, 9.1]	42.5 [35.4, 49.7]	0.03 [0.01, 0.04]	0.00	0.977 [0.962, 0.988]	0.69 [0.64, 0.74]
PPO, shield at deploy	-101.6 [-194.0, -46.2]	312.6 [167.3, 450.5]	1021.3 [788.9, 1238.5]	0.01 [0.00, 0.01]	0.00	0.994 [0.987, 0.999]	0.00 [0.00, 0.00]
Shaped, shield at deploy	-427.3 [-519.0, -318.1]	9.7 [6.3, 13.4]	73.4 [46.8, 105.7]	0.04 [0.01, 0.07]	0.00	0.966 [0.937, 0.992]	0.52 [0.38, 0.65]
PPO-Lag, shield at deploy	-131.8 [-195.0, -76.4]	8.5 [6.8, 10.0]	89.9 [59.4, 124.5]	0.02 [0.01, 0.05]	0.00	0.981 [0.966, 0.993]	0.49 [0.35, 0.59]

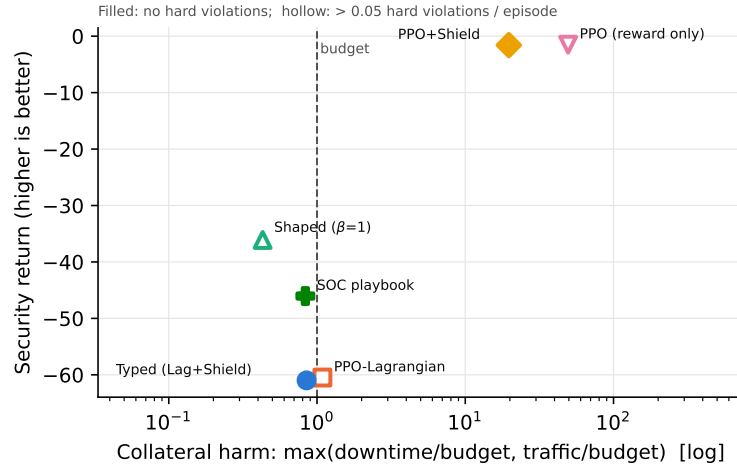


Figure 2: Security return versus normalised collateral harm (log scale) under the training distribution; hollow markers indicate hard-constraint violations.

playbook, Wilcoxon signed-rank tests on CRN-paired episodes, all Holm-corrected. The full protocol is in the artefact (docs/methodology.md).

6 Results

RQ1: Maximising reward is maximally harmful, and penalties are a price. Reward-only PPO reaches a near-perfect security return (-1.5; Table 3) by severing the OT controller for 59.82 of 100 steps per episode, keeping production hosts offline for 494.1 host-steps (budget 10), blocking 1181.0 units of legitimate traffic (budget 50) and destroying evidence 4.30 times per episode. The shield alone (PPO+Shield) removes the hard violations but not the budget harm (196.8 and 845.6). Reward shaping with $\beta = 1$ keeps both budgets and almost never isolates the controller, yet destroys evidence 3.02 times per episode and violates a hard constraint in 94.3% of episodes, although each destruction costs ten times a server-step of downtime. The agent has simply priced the irreversible harm in, and that is where its higher security return (-36.1 vs. -61.0 for TYPED; $p_{\text{Holm}} = 0.00601$) comes from. The β sweep (Figure 4) shows the trade-off:

- with $\beta \leq 1$, evidence is destroyed in at least 94.3% of episodes ($\beta = 0.3$: 96.0%);
- with $\beta \geq 3$, harm disappears but security collapses to -129.5 ($\beta = 3$) and -187.2 ($\beta = 10$).

No penalty weight gives both safety and security, so the weight is a tuning burden, not a guarantee.

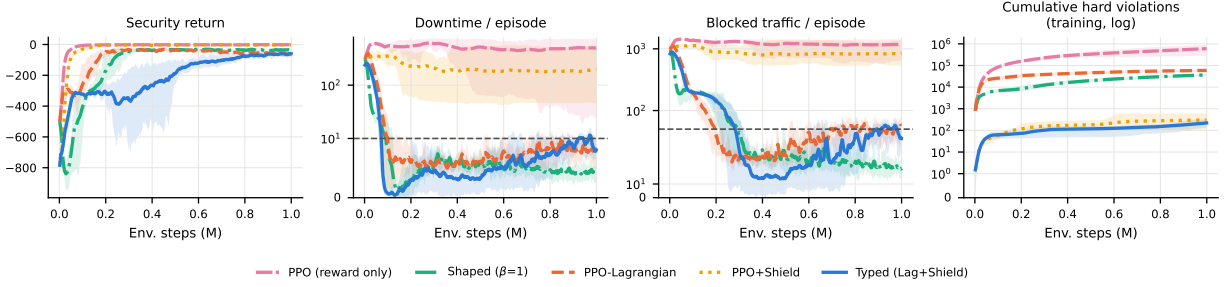


Figure 3: Training dynamics (mean and 10–90% band over seeds). Dashed lines are budgets. The right panel counts hard violations committed *during training* (log scale).

RQ2: Typing the constraints. TYPED satisfies both budgets in expectation (downtime 8.0, traffic 42.5). It is free of hard violations in 97.7% of episodes (47/2000 episodes with a violation), all of them monitor-relative H1 misses; the OT rule is never violated. PPO-Lagrangian treats evidence and the OT rule as zero-budget constraints. It ends training with multipliers of $\lambda_{\text{evid}} \approx 23.4$ and $\lambda_{\text{crit}} \approx 3.0$, yet still commits a hard violation in 50.8% of episodes ($p_{\text{Holm}} = 0.00601$) and exceeds the traffic budget on average (54.4). Expectation constraints are the wrong contract for irreversible harm: a multiplier only grows *after* violations have happened, so violations accumulate throughout training (Figure 3, right) and persist at deployment. Security is indistinguishable (-61.0 vs. -60.5; $p_{\text{Holm}} = 1$), and TYPED meets all four constraints in about twice as many episodes (69.5% vs. 33.8%; $p_{\text{Holm}} = 0.00601$). Against the incumbent playbook, whose mean harm defines the budgets, TYPED incurs the same downtime and traffic (paired CRN tests, $p_{\text{Holm}} = 0.649$ and 1) but a lower security return (-61.0 vs. -46.0; $p_{\text{Holm}} = 1.2 \times 10^{-10}$).

RQ3: The shield belongs in the training loop. Attaching the shield only at deployment (bottom block of Table 3) removes most hard violations, but the policy then acts in states its training never visited.

- **Shaped PPO** learned “reimage without imaging” as its main remediation, and its security collapses (-36.1 $\rightarrow$ -427.3; $p_{\text{Holm}} = 0.00601$).
- **PPO-Lagrangian** degrades on average (-60.5 $\rightarrow$ -131.8; IQM -58.8 $\rightarrow$ -102.4) and its traffic rises to 89.9. The effect varies widely across seeds and is not significant after correction ($p_{\text{Holm}} = 0.182$).
- **Reward-only PPO** with the shield still exceeds the budgets by an order of magnitude.

Training with the shield lets the policy learn the “image, then reimage” sequence. TYPED reaches a better return than every deploy-only variant at equal or lower harm.

RQ4: A held-out attacker. Against the unseen low-and-slow attacker (Table 4) every defender degrades, and every one, including the playbook, exceeds the budgets: budgets hold only in expectation under the training distribution. H2 still holds by construction. H1’s monitor-relative gap widens as detection gets worse: TYPED is free of hard violations in 90.1% of episodes, against 33.4% for PPO-Lagrangian and 0.9% for shaping. The residuals come from images that predate a new, undetected compromise. Adding an image-freshness window to H1 at deployment (Table 5) narrows that window. Requiring the image to be at most three steps old raises the violation-free rate against the stealthy attacker from 90.1% to 98.0% (one step: 99.6%), at a small cost in security. Under the training distribution, however, tightening the rule only at deployment costs security (-61.0 $\rightarrow$ -104.1 for one step) and pushes traffic towards or over budget (55.7). This is the same train/deploy mismatch as in RQ3, and it argues for training with the rule that will be deployed.

Sensitivity to model parameters. Re-evaluating the deployed policies under seven perturbed simulator settings (Table 6) changes absolute numbers, most strongly when detection probability drops by 25%. It never changes the ordering of the learned methods: TYPED has the fewest hard violations and the highest probability of meeting all constraints in every variant, followed by PPO-Lagrangian and then shaping, at comparable security to PPO-Lagrangian.

Table 4: Out-of-distribution evaluation against the held-out low-and-slow (Stealthy) attacker.

Method	Security return $\uparrow$	Downtime $\downarrow$ (budget 10)	Blocked traffic $\downarrow$ (budget 50)	Evidence destroyed $\downarrow$ (budget 0)	Critical viol. $\downarrow$ (budget 0)	$P(\text{no hard viol.}) \uparrow$	$P(\text{all satisfied}) \uparrow$
SOC playbook	-194.8	32.7	133.0	0.00	0.00	1.000	0.03
PPO (reward only)	-10.5 [-18.8, -4.2]	502.0 [294.5, 677.2]	1194.3 [963.5, 1411.3]	5.31 [2.13, 9.79]	60.77 [34.42, 84.86]	0.002 [0.000, 0.006]	0.00
Shaped ($\beta=1$)	-218.1 [-246.2, -194.8]	31.8 [26.6, 36.6]	128.6 [108.2, 147.2]	6.86 [5.52, 7.97]	0.03 [0.01, 0.06]	0.009 [0.000, 0.026]	0.00
PPO-Lagrangian	-273.7 [-294.2, -250.2]	37.7 [34.6, 40.5]	177.7 [162.3, 192.5]	2.47 [0.86, 4.32]	0.76 [0.21, 1.38]	0.334 [0.158, 0.533]	0.01 [0.00, 0.01]
PPO+Shield	-4.5 [-7.3, -2.7]	200.3 [62.1, 347.7]	852.1 [663.5, 1066.8]	0.01 [0.00, 0.02]	0.00	0.993 [0.984, 1.000]	0.00
Typed (Lag+Shield)	-226.4 [-249.9, -200.3]	32.1 [27.5, 36.1]	132.8 [112.8, 149.9]	0.11 [0.06, 0.16]	0.00	0.901 [0.853, 0.948]	0.06 [0.01, 0.14]

Table 5: Typed policies deployed with H1 tightened by an image-freshness window (evaluation only; mean over seeds, 100 CRN episodes per attacker).

Attackers	H1 variant	Return	Traffic	Evidence destroyed	$P(\text{no hard viol.})$
training	H1 (no window)	-61.0	42.5	0.025	0.977
training	H1 + image age ≤ 3	-79.9	48.1	0.013	0.988
training	H1 + image age ≤ 1	-104.1	55.7	0.003	0.997
stealthy (OOD)	H1 (no window)	-226.4	132.8	0.108	0.901
stealthy (OOD)	H1 + image age ≤ 3	-231.2	131.6	0.021	0.980
stealthy (OOD)	H1 + image age ≤ 1	-241.3	128.1	0.005	0.996

7 Discussion and Threats to Validity

Implications for ACD design. Three lessons carry over to other environments. (i) *Separate the signals.* With harm emitted as cost channels rather than folded into reward, any method’s collateral damage is measurable, including a reward-only baseline that looks best on the usual security metric. (ii) *Choose the mechanism by type.* A penalty or a multiplier turns an irreversible harm into a price. A shield that encodes the operational rule the SOC already follows (image before reimage; never sever the OT controller) prevents it, and leaves budget-type harms to the Lagrangian relaxation, which handles them well. (iii) *State guarantees relative to the monitor.* A shield built on SOC observables is only as good as detection. Reporting residuals, and testing against a stealthier attacker, makes this limit visible rather than hiding it behind “safe by construction”. In this small network a well-engineered playbook remains a strong baseline, with better security at the same harm. The contribution here is not that RL beats playbooks, but how a learned defender must be constrained before it can be trusted alongside one.

Threats. *Internal:* hyper-parameters were shared, not tuned per condition; the β sweep bounds the effect of tuning the shaping baseline. *Construct:* downtime and traffic are proxies, and evidence is modelled as a binary per-incident property, whereas real artefacts are graded by volatility [7]. *External:* one 12-host topology with scripted attackers; our claims concern safety *mechanisms*, not deployment-ready agents; porting the cost channels to CybORG/CAGE-4 is future work. *Conclusion:* ten seeds, CRN pairing, bootstrap CIs and Holm correction; near-zero violation rates are reported with exact binomial upper bounds.

8 Conclusion

A cyber-defence agent should not be allowed to buy security with harm it cannot undo. In SAFEACD-SIM, reward maximisation bought security by severing the OT controller and destroying evidence. Penalties and Lagrange multipliers turned that harm into a price the agent was willing to pay. A typed design, with budgets for recoverable harm and an observation-based shield for irreversible harm, kept collateral damage within the playbook’s envelope and made hard violations rare and attributable to monitoring gaps. Next steps are to port the cost channels to CybORG CAGE-4, model graded (volatility-ordered) evidence, and synthesise shields from SOC runbooks.

Artefact availability. Simulator, agents, configuration, raw evaluation records and analysis scripts: [TODO: anonymised repository / Zenodo DOI].

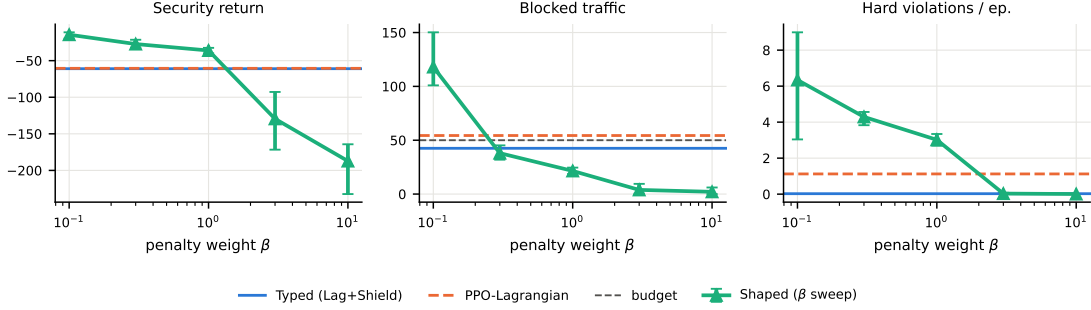


Figure 4: Reward shaping across penalty weights β (mean and 95% CI over seeds), with TYPED and PPO-Lagrangian as horizontal references.

Table 6: Sensitivity of deployed policies to simulator parameters (training-distribution attackers, 50 CRN episodes each, mean over seeds). Cells: security return / hard violations per episode / $P(\text{all constraints satisfied})$.

Variant	Playbook	Typed	Lag	Shaped
base	-42 / 0.00 / 0.63	-57 / 0.02 / 0.71	-56 / 1.09 / 0.34	-31 / 2.81 / 0.07
detect -25detect +25restore 1 step	-43 / 0.00 / 0.84	-58 / 0.02 / 0.80	-55 / 1.06 / 0.40	-31 / 2.86 / 0.07
restore 3 steps	-42 / 0.00 / 0.51	-57 / 0.02 / 0.62	-55 / 1.03 / 0.30	-32 / 2.77 / 0.06
false alerts x5	-54 / 0.00 / 0.44	-97 / 0.06 / 0.41	-102 / 1.22 / 0.15	-62 / 4.85 / 0.03
exploit p=0.9	-61 / 0.00 / 0.43	-79 / 0.03 / 0.59	-74 / 1.35 / 0.29	-40 / 3.42 / 0.06

References

- [1] Joshua Achiam, David Held, Aviv Tamar, and Pieter Abbeel. Constrained policy optimization. In *Proceedings of the 34th International Conference on Machine Learning (ICML)*, volume 70 of *PMLR*, pages 22–31, 2017.
- [2] Rishabh Agarwal, Max Schwarzer, Pablo Samuel Castro, Aaron Courville, and Marc G. Bellemare. Deep reinforcement learning at the edge of the statistical precipice. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 34, 2021.
- [3] Mohammed Alshiekh, Roderick Bloem, Rüdiger Ehlers, Bettina Könighofer, Scott Niekum, and Ufuk Topcu. Safe reinforcement learning via shielding. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 32, 2018.
- [4] Eitan Altman. *Constrained Markov Decision Processes*. Chapman and Hall/CRC, 1999.
- [5] Elizabeth Bates, Chris Hicks, and Vasilios Mavroudis. Less is more? Rewards in RL for cyber defence. *arXiv preprint arXiv:2503.03245*, 2025.
- [6] Elizabeth Bates, Chris Hicks, and Vasilios Mavroudis. Beyond rewards in reinforcement learning for cyber defence. *arXiv preprint arXiv:2602.04809*, 2026.
- [7] Dominique Brezinski and Tom Killalea. Guidelines for evidence collection and archiving. RFC 3227, Internet Engineering Task Force, 2002.
- [8] Ashutosh Dutta, Ehab Al-Shaer, and Samrat Chatterjee. Constraints satisfiability driven reinforcement learning for autonomous cyber defense. In *Proceedings of the 1st International Conference on Autonomous Intelligent Cyber-Defence Agents (AICA)*, 2021. arXiv:2104.08994.
- [9] Myles Foley, Chris Hicks, Kate Highnam, and Vasilios Mavroudis. Autonomous network defence using reinforcement learning. In *Proceedings of the 2022 ACM Asia Conference on Computer and Communications Security (ASIA CCS)*, 2022.

- [10] Javier García and Fernando Fernández. A comprehensive survey on safe reinforcement learning. *Journal of Machine Learning Research*, 16(42):1437–1480, 2015.
- [11] Nathan Grinsztajn, Johan Ferret, Olivier Pietquin, Philippe Preux, and Matthieu Geist. There is no turning back: A self-supervised approach for reversibility-aware reinforcement learning. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 34, 2021.
- [12] Shangding Gu, Long Yang, Yali Du, Guang Chen, Florian Walter, Jun Wang, and Alois Knoll. A review of safe reinforcement learning: Methods, theories and applications. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 46(12), 2024.
- [13] Kim Hammar and Rolf Stadler. Intrusion prevention through optimal stopping. *IEEE Transactions on Network and Service Management*, 19(3), 2022.
- [14] Peter Henderson, Riashat Islam, Philip Bachman, Joelle Pineau, Doina Precup, and David Meger. Deep reinforcement learning that matters. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 32, 2018.
- [15] Achraf Hsain and Sultan Almuhammadi. Shielded analysis: Certification and characterization of defensibility in systems under adversarial interaction. *arXiv preprint arXiv:2606.13621*, 2026.
- [16] Shengyi Huang and Santiago Ontañón. A closer look at invalid action masking in policy gradient algorithms. In *Proceedings of the International FLAIRS Conference*, volume 35, 2022.
- [17] Saeid Jamshidi, Negar Shahabi, Foutse Khomh, Carol Fung, and Mohammad Hamdaqa. Multi-agent LLM governance for safe two-timescale reinforcement learning in SDN-IoT defense. *arXiv preprint arXiv:2604.01127*, 2026.
- [18] Jiaming Ji, Jiayi Zhou, Borong Zhang, Juntao Dai, Xuehai Pan, Ruiyang Sun, Weidong Huang, Yiran Geng, Mickel Liu, and Yaodong Yang. OmniSafe: An infrastructure for accelerating safe reinforcement learning research. *Journal of Machine Learning Research*, 25(285):1–6, 2024.
- [19] Karen Kent, Suzanne Chevalier, Tim Grance, and Hung Dang. Guide to integrating forensic techniques into incident response. Technical Report SP 800-86, National Institute of Standards and Technology, 2006.
- [20] Mitchell Kiely et al. CAGE challenge 4: A scalable multi-agent reinforcement learning gym for autonomous cyber defence. *AI Magazine*, 46(3), 2025. doi: 10.1002/aaai.70021. TODO-VERIFY full author list.
- [21] Alexander Kott, editor. *Autonomous Intelligent Cyber Defense Agent (AICA): A Comprehensive Guide*. Springer, 2023.
- [22] Averill M. Law. *Simulation Modeling and Analysis*. McGraw-Hill, 5th edition, 2015.
- [23] National Institute of Standards and Technology. Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. Technical Report SP 800-61 Rev. 3, NIST, 2025. TODO-VERIFY author list.
- [24] Jakob Nyberg, Teodor Sommestad, Andrei Buhaiu, Joakim Loxdal, Pontus Johnson, and Mathias Ekstedt. A cyber range evaluation of autonomous network incident response agents. *arXiv preprint arXiv:2609.16541*, 2026.
- [25] Gregory Palmer, Chris Parry, Daniel J. B. Harrold, and Chris Willis. Deep reinforcement learning for autonomous cyber operations: A survey. *arXiv preprint arXiv:2310.07745*, 2023.
- [26] Alex Ray, Joshua Achiam, and Dario Amodei. Benchmarking safe exploration in deep reinforcement learning. Technical report, OpenAI, 2019.
- [27] John Schulman, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov. Proximal policy optimization algorithms. *arXiv preprint arXiv:1707.06347*, 2017.

- [28] Maxwell Standen, Martin Lucas, David Bowman, Toby J. Richer, Junae Kim, and Damian Marriott. CybORG: A gym for the development of autonomous cyber agents. In *IJCAI-21 1st International Workshop on Adaptive Cyber Defense*, 2021. arXiv:2108.09118.
- [29] Adam Stooke, Joshua Achiam, and Pieter Abbeel. Responsive safety in reinforcement learning by PID Lagrangian methods. In *Proceedings of the 37th International Conference on Machine Learning (ICML)*, volume 119 of *PMLR*, pages 9133–9143, 2020.
- [30] Isaac Symes Thompson, Alberto Caron, Chris Hicks, and Vasilios Mavroudis. Entity-based reinforcement learning for autonomous cyber defence. In *Proceedings of the 1st International Workshop on Autonomous Cybersecurity (AutonomousCyber)*, *ACM CCS*, 2024. arXiv:2410.17647.
- [31] Chen Tessler, Daniel J. Mankowitz, and Shie Mannor. Reward constrained policy optimization. In *International Conference on Learning Representations (ICLR)*, 2019.
- [32] Konur Tholl, François Rivest, Mariam El Mezouar, Adrian Taylor, and Ranwa Al Mallah. Towards production-worthy simulation for autonomous cyber operations. *arXiv preprint arXiv:2508.19278*, 2025.
- [33] TODO-VERIFY authors. Safety-contract graph multi-agent reinforcement learning for autonomous network security response. *arXiv preprint arXiv:2606.13832*, 2026.
- [34] TODO-VERIFY authors. Building better environments for autonomous cyber defence. *arXiv preprint arXiv:2604.08805*, 2026.
- [35] Sanyam Vyas, John Hannay, Andrew Bolton, and Pete Burnap. Automated cyber defence: A review. *arXiv preprint arXiv:2303.04926*, 2023.